

Apply Vulnerability Assessment Techniques

Final Report — Asset Discovery and Vulnerability Scanning

Nmap-Based Discovery and Vulnerability Scanning Against the HVMC Lab and an Authorized External Host

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Rubric	Apply Vulnerability Assessment Techniques
Scanning Host	HVMC-KALI (Kali Linux, Nmap 7.94)
Scan Targets	Internal lab segment 192.168.64.0/24; external authorized host scanme.nmap.org
Document Version	1.0
Prepared By	Sabitha S Karanavar
Report Date	September 8, 2026

1. Rubric Cross-Reference

This report consolidates both required components of the “Apply Vulnerability Assessment Techniques” rubric line into a single submission.

Rubric Requirement	Section	Evidence
Asset discovery scan: systems/services, critical asset ID, network mapping	Section 2	nmap -sn host sweep + nmap -sV -O service/OS detection
Vulnerability scan: configuration, findings, classification	Section 3	nmap -sV --script vuln against scanme.nmap.org (149 unique CVEs)

2. Asset Discovery Scan

2.1 Scan Configuration and Methodology

A two-stage discovery approach was used against the lab's active segment, 192.168.64.0/24 (UTM's macOS Shared Network / vmnet range — see project change log for the addressing correction from the originally planned 192.168.50.0/24). Stage 1 performed a ping sweep to identify live hosts without touching ports; Stage 2 ran service/version and OS detection against each host found alive.

```
sudo nmap -sn 192.168.64.0/24
sudo nmap -sV -O -p- --open 192.168.64.1
sudo nmap -sV -O -p- --open 192.168.64.30
```

-sn restricts the scan to host discovery (no port scan), keeping Stage 1 fast and low-noise. -sV -O -p- --open then probes every TCP port on each live host for service/version banners and OS fingerprint, reporting only ports found open.

2.2 Discovered Systems and Services

Host	Role	Open Ports / Notes
192.168.64.1	macOS host / vmnet gateway	53/tcp open (domain — DNS), 62906/tcp open (unrecognized service); OS

Host	Role	Open Ports / Notes
		fingerprint inconclusive (no exact match in Nmap's database). Excluded from lab scope — this is the hypervisor uplink, not a simulated HVMC asset.
192.168.64.30	HVMC-KALI (scanning/analyst host)	No open ports found on a full 1–65535 TCP sweep. Consistent with a hardened analyst workstation that exposes no listening services.
192.168.64.10 (HVMC-DC01)	Domain controller (Samba4 AD DC/DNS)	Not discovered in this scan — VM is currently inaccessible pending console-password recovery (see Section 2.4). To be re-scanned once restored.
192.168.64.20 (HVMC-CL01)	Domain-joined client	Not yet built. To be added to a future discovery pass once provisioned.

2.3 Critical Asset Identification

Two critical-asset findings from this pass: HVMC-KALI is the current de facto critical asset in the live environment — it is the sole active scanning/analysis platform, and its compromise would mean loss of the team's security tooling and visibility. Its clean port sweep (no exposed services) is itself a positive security finding. HVMC-DC01 remains the designated long-term critical asset by design (it will hold Kerberos/LDAP/DNS for the entire hvmc.local domain once restored) — its current inaccessibility is documented here as a known scope limitation, not a scan failure.

2.4 Basic Network Mapping

The live environment is a single flat segment (192.168.64.0/24) behind the macOS host acting as gateway/DNS resolver for the vmnet. Only one simulated HVMC asset (HVMC-KALI) is currently online; HVMC-DC01 is offline pending console-password recovery, and HVMC-CL01 has not yet been provisioned. This scan reflects the live network as of the report date and will be re-run to add both hosts once lab access is restored — consistent with how incomplete builds are documented elsewhere in this project.

3. Vulnerability Scan

3.1 Scan Configuration and Methodology

Target: scanme.nmap.org (45.33.32.156), the Nmap Project's own test host, which is explicitly authorized for scanning via Nmap (no more than a dozen scans/day, no exploit or denial-of-service testing). This target was chosen so the vulnerability-scan requirement did not depend on lab hosts that are temporarily offline.

```
nmap -sV scanme.nmap.org
nmap -sV --script vuln scanme.nmap.org
```

-sV performs service/version detection, which the NSE vuln scripts need to match services to known CVE/exploit databases. --script vuln runs Nmap's vulnerability-detection script category, including the vulners engine (cross-references detected service versions against the Vulners.com CVE/exploit database), http-csrf, http-enum, http-dombased-xss, http-stored-xss, and a pre-scan broadcast-avahi-dos check.

3.2 Summary of Findings

Port	Service	Finding
22/tcp	OpenSSH 6.6.1p1 (Ubuntu)	A version from 2014 with a large, actively-tracked CVE history; vulners matched dozens of CVEs including CVE-2023-38408 (9.8, remote code execution).
80/tcp	Apache httpd 2.4.7 (Ubuntu)	Also a 2014-era version; vulners matched the largest single block of findings, including several CVSS 9.8–10.0 entries. http-enum found a browsable /images/ directory. http-csrf found two forms (/search/) without visible CSRF tokens. No DOM-based or stored XSS was found.

Port	Service	Finding
139, 445/tcp	netbios-ssn, microsoft-ds	Filtered (no response) — not assessable from outside the host's network.
9929, 31337/tcp	nping-echo, tcpwrapped	Open, expected — these are intentionally left open by the Nmap Project as part of the scanme.nmap.org test host.

3.3 Vulnerability Classification

149 unique CVEs were matched across both services by the vulners NSE script. Classified by CVSS base score:

Severity	Count	Representative CVEs
Critical (9.0–10.0)	27	CVE-2023-38408 (OpenSSH RCE), CVE-2021-44790 (Apache mod_lua buffer overflow), CVE-2017-7679 (Apache mod_mime buffer over-read), CVE-2016-1908 (OpenSSH X11 forwarding)
High (7.0–8.9)	57	CVE-2016-5387 (Apache httpoxy), CVE-2021-44224 (Apache SSRF/DoS via mod_proxy), CVE-2020-15778 (OpenSSH scp command injection)
Medium (4.0–6.9)	59	CVE-2023-48795 (Terrapin SSH protocol downgrade), CVE-2014-0226 (Apache mod_status race condition)
Low (0.1–3.9)	6	Minor information-disclosure and low-impact issues

Both services are running versions from 2013–2014 (OpenSSH 6.6.1p1, Apache 2.4.7) — over a decade of missed patches accounts for the unusually high CVE count. This host is intentionally kept outdated by the Nmap Project as a realistic, legal scanning target, which is exactly what makes it useful for demonstrating classification methodology.

4. Security Implications

- Outdated service versions carry compounding risk: a single unpatched host accumulates vulnerabilities across every version it never upgraded through, not just the most recent CVE.
- The CSRF findings on scanme.nmap.org's /search/ forms illustrate a common web-application gap: forms that accept state-changing input without an anti-CSRF token are exploitable via a crafted link or page, even without stealing credentials.
- The clean port sweep on HVMC-KALI reinforces a core hardening principle: an analyst workstation should expose the minimum possible attack surface, since it holds tooling and, often, credentials.
- HVMC-DC01's absence from this discovery pass is itself a security-relevant fact for a real organization: an inventory tool that only "sees" what's currently online can create false confidence that fewer assets exist than actually do — asset inventories need a process for accounting for known-but-offline systems, not just live-scan results.

5. Conclusion

Both components of the Apply Vulnerability Assessment Techniques rubric are satisfied: an asset discovery scan documented the live hosts, services, and network layout of the current environment along with an honest accounting of assets not yet online (Section 2); and a vulnerability scan against an authorized external host produced a full scan configuration, findings summary, and CVSS-based classification of 149 unique vulnerabilities (Section 3), with the practical security implications of each drawn out in Section 4.

6. References / Sources

- Nmap Security Scanner, scanme.nmap.org usage policy — nmap.org/book/testing.html.
- Vulners.com CVE/exploit database, matched via the Nmap vulners NSE script.
- NIST National Vulnerability Database (nvd.nist.gov) for CVSS base scores cited in Section 3.3.
- windows-to-samba4-substitution-plan.md and weeks-1-4-rubric-integration-plan.md — HVMC lab architecture and addressing history referenced in Section 2.

Prepared for: Sabitha — Healthcare IAM Operations Home Lab | Cyber Threats and Vulnerabilities rubric — Apply Vulnerability Assessment Techniques (final report)